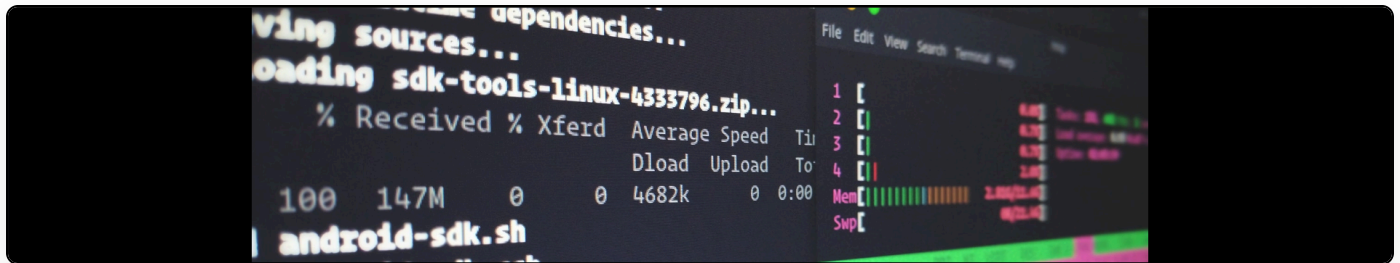


Evaluating the security of the JSONRequest object

Cite as: Martin Paul Eve, "Evaluating the security of the JSONRequest object", *eve.gd: Martin Paul Eve*, May 15, 2007, <https://doi.org/10.59348/nsh00-ych18>.



A proposed extension to the currently supported set of ...Request objects is JSONRequest, interesting from a security point of view because the proponents of the project wish to allow JSONRequest to violate the Same Origin Policy. This post will give a brief overview of the security features touted by JSONRequest and of how they potentially could allow an attacker to compromise a site more effectively.

"JSONRequest does not send or receive cookies or passwords in HTTP headers. This avoids false authorization situations. Knowing the name of a site does not grant the ability to use its browser credentials." This is good as it prevents CSRF attacks via the object.

"JSONRequest works only with JSON text. The JSONRequest cannot be used to access legacy data or documents or scripts. This avoids attacks on internal websites which assume that access is sufficient authorization. A request will fail if the response is not perfectly UTF-8 encoded. Suboptimal aliases and surrogates will fail. A request will fail if the response is not strictly in JSON format. A request will fail if the server does not respond to POST with a JSON payload." However, by the time the request has been issued it may already be too late despite the "request failing". Many server side scripts will act upon a request before delivering data and so the fact that the response was invalid does not mean that the server did not act upon the request. Potential uses for this may be applications which contain authorization information solely via GET parameters and where a single request is required to complete an action.

"Responses will be rejected unless they contain a JSONRequest content type. This makes it impossible to use JSONRequest to obtain data from insecure legacy servers." As well as the risks detailed above, XSS vulnerabilities may allow the attacker to craft the response into a JSON format.

"JSONRequest reveals very little error information. In some cases, the goal of a miscreant is to access the information that can be obtained from an error message. JSONRequest does not return this information to the requesting script. It may provide the information to the user through a log or other mechanism, but not in a form that the script can ordinarily access." This is good, but not fun to debug!

"JSONRequest accumulates random delays before acting on new requests when previous requests have failed. This is to frustrate timing analysis attacks and denial of service attacks." In this security mechanism "frustrate" is the key word. It would not be difficult to craft some rapidly fired valid requests in between the failing requests as *"each successful request reduces the delay by 10 milliseconds until the delay goes to zero."*

If JSONRequest is adopted by major providers then more and more sites will be returning valid JSON data. It will not be long before attacks begin to exploit this.